13.2 Getting your bearings

Sprint 13 Incident Investigation

← Use the **Document tabs** to locate the notes for each task in this investigation.

02 - ALERT: Brute-force attack detected!
~~has the alert~~

02 - Finding the Attacking Evidence
the most probable IP address associated with the unusually high number of requests reported by the junior sysadmin in the original alert is **40.80.148.42**

02 - Determining the scanning tool
The organization that developed the web vulnerability scanning tool used by the threat actor is ***Acunetix***

13.2.1 Device

13.2.1 Finding the attacking device

Instructions for completing this task are located here. Use this worksheet to keep notes as you complete it.

ADD YOUR NOTES HERE

40.80.148.42

This is the IP with unusually high requests (reconnaissance/scanning)

23.22.63.114

This is the IP that was pre-staged for the actual attack

13.2.2 Tool

13.2.2 Determining the tool

Instructions for completing this task are located here. Use this worksheet to keep notes as you complete it.

ADD YOUR NOTES HERE

Acunetix was the web vulnerability scanning tool

13.2.3 Exploited CMS

13.2.3 Identifying the exploited CMS

Instructions for completing this task are located here. Use this worksheet to keep notes as you complete it.

ADD YOUR NOTES HERE

Joomla is the CMS most likely being used by imreallynotbatman.com

13.2.4 Defacement image’s filename

13.2.4 Establishing the defacement image's filename

Instructions for completing this task are located here. Use this worksheet to keep notes as you complete it.

ADD YOUR NOTES HERE

Poisonivy-is-coming-for-you-batman.jpeg is the filename associated with the file used to deface the imreallynotbatman.com website

13.2.5 FQDN

13.2.5 Associating the malicious FQDN

Instructions for completing this task are located here. Use this worksheet to keep notes as you complete it.

ADD YOUR NOTES HERE

The fully qualified domain name (FQDN) that was used in this attack to resolve to the malicious IP address via dynamic DNS was ***prankglassinebracket.jumpingcrab.com***

13.2.6 Pre-staging IP

13.2.6 Discovering the pre-staging IP address

Instructions for completing this task are located here. Use this worksheet to keep notes as you complete it.

ADD YOUR NOTES HERE

The IP address the threat actor linked to domains that were preconfigured (“pre-staged”) for the attack on Wayne Enterprises was ***23.22.63.114***

13.2.7 APT email

13.2.7 Using OSINT to confirm the APT group’s email address

Instructions for completing this task are located here. Use this worksheet to keep notes as you complete it.

ADD YOUR NOTES HERE

The email address most likely linked to the threat actor is ***lillian@po1s0n1vy.com***

13.2.8 Brute-force IP

13.2.8 Assessing the brute-forcing IP address

Instructions for completing this task are located here. Use this worksheet to keep notes as you complete it.

ADD YOUR NOTES HERE

The IP address is most likely conducting a brute force password attack targeting imreallynotbatman.com is ***23.22.63.114***

13.2.9 Malware filename

13.2.9 Figuring out the malicious executable's filename

Instructions for completing this task are located here. Use this worksheet to keep notes as you complete it.

ADD YOUR NOTES HERE

The filename of the malicious executable uploaded by the threat actor is ***3791.exe***

13.2.10 MD5 hash

13.2.10 Locating the MD5 hash of that executable

Instructions for completing this task are located here. Use this worksheet to keep notes as you complete it.

ADD YOUR NOTES HERE

The MD5 hash value of that executable file uploaded by the threat actor is ***AAE3F5A29935E6ABCC2C2754D12A9AF0***

13.2.11 SHA256 hash

13.2.11 Using OSINT to find the SHA256 of an APT group's custom malware

Instructions for completing this task are located here. Use this worksheet to keep notes as you complete it.

ADD YOUR NOTES HERE

According to GCPD, when this threat actor's initial compromise attempts are unsuccessful, they typically follow up by sending a spear phishing email containing custom malware to their target. This malware is generally linked to the group's original attack infrastructure.

The SHA256 hash of this malware sample is
9709473ab351387aab9e816eff3910b9f28a7a70202e250ed46dba8f820f34a8

13.2.12 Custom hex

13.2.12 Figuring out the malware’s custom hex

Instructions for completing this task are located here. Use this worksheet to keep notes as you complete it.

ADD YOUR NOTES HERE

The unique hexadecimal code linked to the custom malware used by the threat actor is

4e 65 6c 20 6d 65 7a 7a 6f 20 64 65 6c 20 63 61 6d 6d 69 6e 6f 20 64 69 20 6e 6f 73 74 72 61 20 76 69 74 61 20 6d 69 20 72 69 74 72 6f 76 61 69 20 70 65 72 20 75 6e 61 20 73 65 6c 76 61 20 6f 73 63 75 72 61

Nel mezzo del cammino di nostra vita mi ritrovai per una selva oscura

13.2.13 WHOIS info

13.2.13 Using OSINT to discover interesting WHOIS information

Instructions for completing this task are located here. Use this worksheet to keep notes as you complete it.

ADD YOUR NOTES HERE

The *decoded* interesting WHOIS data associated with the threat actor's staged domain is

lasciate ogni speranza, voi ch'intrate

6c 61 73 63 69 61 74 65 20 6f 67 6e 69 20 73 70 65 72 61 6e 7a 61 2c 20 76 6f 69 20 63 68 27 69 6e 74 72 61 74 65

13.3 Analyzing the brute force attack

13.3.1 Passwords used

13.3.1 Identifying passwords used

Instructions for completing this task are located here. Use this worksheet to keep notes as you complete it.

ADD YOUR NOTES HERE

The very first password used in the attack was ***12345678***

13.3.2 6-char passwords

13.3.2 Figuring out 6-character passwords

Instructions for completing this task are located here. Use this worksheet to keep notes as you complete it.

ADD YOUR NOTES HERE

Threat intelligence tells us this threat actor is a fan of the band Coldplay — and that their favorite song is 6-characters long.

The password that matches a 6-character long Coldplay song is ***Yellow***

13.3.3 Admin password

13.3.3 Establishing the correct admin password

Instructions for completing this task are located here. Use this worksheet to keep notes as you complete it.

ADD YOUR NOTES HERE

The password that successfully granted admin access to the content management system operating on imreallynotbatman.com was

batman

13.3.4 Average password length

13.3.4 Determining the average password length

Instructions for completing this task are located here. Use this worksheet to keep notes as you complete it.

ADD YOUR NOTES HERE

The average length of the passwords is ***6 characters***

13.3.5 Seconds between events

13.3.5 Calculating seconds elapsed between two events

Instructions for completing this task are located here. Use this worksheet to keep notes as you complete it.

ADD YOUR NOTES HERE

The time interval *(in seconds)* between the moment the brute force scan discovered the correct password and when the compromised login occurred was ***92.17***

13.3.6 Unique password count

13.3.6 Reckoning the unique password count

Instructions for completing this task are located here. Use this worksheet to keep notes as you complete it.

ADD YOUR NOTES HERE

the total number of distinct passwords tried during the brute force attack was ***412***

13.4 Digging in deeper

13.4.1 Host IP

13.4.1 Determining a host's IP address

Instructions for completing this task are located here. Use this worksheet to keep notes as you complete it.

ADD YOUR NOTES HERE

we8105desk was most likely using the ***192.168.250.100*** IP address on 2016-08-24

13.4.2 Least frequent alert

13.4.2 Calculating the least frequent alert

Instructions for completing this task are located here. Use this worksheet to keep notes as you complete it.

ADD YOUR NOTES HERE

The Suricata signature *(associated with the detection of Cerber malware)* that generated the lowest number of alerts was ***2816763***

13.4.3 Ransomware FQDN

13.4.3 Working out which FQDN the ransomware redirects to

Instructions for completing this task are located here. Use this worksheet to keep notes as you complete it.

ADD YOUR NOTES HERE

The FQDN that the Cerber ransomware tries to redirect the user to post-encryption is cerberhhyed5frqa.xmfir0.win

13.4.4 Malicious URL by host

13.4.4 Discovering the first malicious URL visited by a host

Instructions for completing this task are located here. Use this worksheet to keep notes as you complete it.

ADD YOUR NOTES HERE

the initial suspicious domain accessed by we8105desk on 2016-08-24 was ***solidaritedeproximite.org***

13.4.5 VB script run during infection

13.4.5 Locating the VB script run during infection

Instructions for completing this task are located here. Use this worksheet to keep notes as you complete it.

ADD YOUR NOTES HERE

As part of the initial Cerber infection, a VB script is executed. The full script content, preceded by the name of the executable that launched it, is stored in script_field_length.

The character count of that particular field's value is ***4490***

13.4.6 USBs

13.4.6 Digging up evidence of USBs connected to a device

Instructions for completing this task are located here. Use this worksheet to keep notes as you complete it.

ADD YOUR NOTES HERE

the label or name of the USB device that Bob Smith inserted is ***MIRANDA_PRI***

13.4.7 File server

13.4.7 Identifying the file server

Instructions for completing this task are located here. Use this worksheet to keep notes as you complete it.

ADD YOUR NOTES HERE

During the ransomware outbreak, Bob Smith's workstation (we8105desk) was linked to a file server.

The IP address of that file server was ***192.168.250.20***

13.4.8 Unique files

13.4.8 Computing unique files encrypted by the ransomware

Instructions for completing this task are located here. Use this worksheet to keep notes as you complete it.

ADD YOUR NOTES HERE

the total number of unique PDF files encrypted by the ransomware on the remote file server was ***257***

13.4.9 Process

13.4.9 Tracking down the responsible process

Instructions for completing this task are located here. Use this worksheet to keep notes as you complete it.

ADD YOUR NOTES HERE

The VBscript found in Locating the VB script run during infection launches 121214.tmp. The ParentProcessId of this initial launch is ***3968***

13.4.10 Counting files

13.4.10 Calculating the number of encrypted files of a specific format

Instructions for completing this task are located here. Use this worksheet to keep notes as you complete it.

ADD YOUR NOTES HERE

401 .txt files within Bob Smith's Windows user profile were encrypted by the Cerber ransomware.

13.4.11 Cryptor's filename

13.4.11 Locating the cryptor’s filename

Instructions for completing this task are located here. Use this worksheet to keep notes as you complete it.

ADD YOUR NOTES HERE

The name of the downloaded file that contains the Cerber ransomware’s cryptor code is ***mhtr.jpg***

13.4.12 Obfuscation

13.4.12 Using OSINT to determine the ransomware's obfuscation technique

Instructions for completing this task are located here. Use this worksheet to keep notes as you complete it.

ADD YOUR NOTES HERE

The obfuscation method that it is most likely employing ***Steganography***